

Controls and compliance checklist

Controls assessment checklist:

Yes	No	Control	Explanation
☐	☒	Least Privilege	<i>Currently, access controls are not restricted; all company employees have full access to internal customer data, which significantly increases the internal threat vector and exposure risk .</i>
☐	☒	Disaster recovery plans	<i>There are zero disaster recovery or business continuity frameworks established, leaving the infrastructure highly vulnerable to prolonged downtime or permanent data loss during an incident .</i>
☐	☒	Password policies	<i>The current baseline requirements for employee credentials are too nominal and weak, making internal accounts easy targets for brute-force or credential-stuffing attacks .</i>
☐	☒	Separation of duties	<i>Critical business tasks lack segregation; day-to-day operations and payroll management are centralized under a single individual (the CEO), increasing the risk of fraud or accidental errors.</i>

☒	☐	Firewall	<i>Active perimeter defense is in place; the current firewall operates on a well-defined set of security rules to filter incoming and outgoing traffic.</i>
☐	☒	Intrusion detection system (IDS)	<i>There is a complete lack of real-time internal network visibility. An IDS must be deployed to analyze traffic patterns and alert on potential security breaches .</i>
☐	☒	Backups	<i>No secure or structured backup schedule exists for critical data, severely undermining the company's ability to recover from a ransomware deployment .</i>
☒	☐	Antivirus software	<i>End-point protection is fully deployed; antivirus solutions are installed across assets and actively maintained by the IT department.</i>
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems	<i>Legacy and end-of-life systems are actively running but lack formalized maintenance intervals, clear playbooks, or standardized patch management protocols.</i>
☐	☒	Encryption	<i>Data-at-rest and data-in-transit remain completely unencrypted within the local databases, failing to protect sensitive user information from</i>

			unauthorized exposure.
☐	☒	Password management system	No centralized vault or manager is utilized, leading to password reuse and a high volume of manual credential reset tickets that drain IT support resources.
☒	☐	Locks (offices, storefront, warehouse)	Physical access control is adequate; robust mechanical locks are deployed across the corporate offices, retail storefront, and inventory warehouse.
☒	☐	Closed-circuit television (CCTV) surveillance	Visual security monitoring is functional and up to date, providing continuous surveillance over all entry and storage points at the physical facility.
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)	Automated fire safety controls, including active alarms and operational sprinkler systems, are installed and functioning correctly across the facility.

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
☐	☒	Only authorized users have access to customers' credit card information.	Perimeter access controls do not exist; cardholder data (CHD) is

accessible by default to all personnel within the network

☐	☒	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.	<i>Credit card information is not encrypted and all employees currently have access to internal data, including customers' credit card information.</i>
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	<i>The company does not currently use encryption to better ensure the confidentiality of customers' financial information.</i>
☐	☒	Adopt secure password management policies.	<i>The existing password policy lacks complexity parameters and is not backed by an enforcement mechanism or a centralized tool .</i>

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
☐	☒	E.U. customers' data is kept private/secured.	<i>Due to the total absence of cryptographic controls and least privilege restrictions, European citizens' personal data is not adequately protected against leaks.</i>
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	<i>There is a plan to notify E.U. customers within 72 hours of a data breach.</i>
☐	☒	Ensure data is properly classified and inventoried.	<i>Current assets have been inventoried/listed, but not classified.</i>
☒	☐	Enforce privacy policies,	<i>Privacy policies, procedures, and</i>

procedures, and processes to properly document and maintain data.

processes have been developed and enforced among IT team members and other employees, as needed.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
☐	☒	User access policies are established.	<i>Controls of Least Privilege and separation of duties are not currently in place; all employees have access to internally stored data.</i>
☐	☒	Sensitive data (PII/SPII) is confidential/private.	<i>Encryption is not currently used to better ensure the confidentiality of PII/SPII.</i>
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.	<i>Data integrity is in place.</i>
☐	☒	Data is available to individuals authorized to access it.	<i>While data is available to all employees, authorization needs to be limited to only the individuals who need access to it to do their jobs.</i>

Recommendations :

- 1. Enforce Least Privilege: Review and restrict employee access levels to ensure that users only have access to data strictly necessary for their specific job functions.**

- 2. Establish a Disaster Recovery & Business Continuity Plan:** Create a well-structured, easy-to-understand strategy to guarantee rapid business recovery in the event of a disaster or major incident.
- 3. Implement Separation of Duties:** Divide critical tasks among different employees to prevent conflicts of interest (e.g., ensuring the person who processes payroll/invoices is not the same person authorized to execute the payments).
- 4. Deploy an Intrusion Detection System (IDS):** Implement an IDS to continuously monitor internal network traffic and verify security logs for unauthorized or malicious activity.
- 5. Upgrade Password Security & Management:** Enforce modern complexity requirements (minimum character counts, special characters, and numbers). Implement a secure, centralized cloud password manager restricted to authorized IT personnel to prevent credential loss, streamline resets, and save IT department resources.
- 6. Implement Secure Off-Site Backups:** Establish a regular backup schedule and ensure copies are stored securely outside the main network infrastructure (e.g., an isolated backup server or secure cloud) to protect against ransomware or network-wide breaches.
- 7. Schedule Legacy System Maintenance:** Define a periodic, documented schedule for the monitoring and maintenance of end-of-life legacy systems to establish clear, standardized intervention methods.
- 8. Enforce Data Encryption:** Implement robust encryption mechanisms to secure sensitive customer data, including credit card details, transactions, and processing logs, both at rest and in transit.